🔒 PRE-ICO SECURITY, COMPLIANCE & ARCHITECTURE AUDIT REPORT

Influencers CRM Backend

Repository: `juanrm2II2/influencers-CRM-backend`

Audit Date: April 10, 2026

Audit Type: Pre-ICO Full Security, Compliance & Architecture Audit

Scope: Backend API, Authentication, Secrets Management, Scraping Integration, Blockchain Readiness, CI/CD & Infrastructure, GDPR/CCPA/KYC Compliance

Classification: CONFIDENTIAL

Report Version: 1.0

⚠️ VERDICT: PARTIALLY READY

The application demonstrates strong backend security fundamentals but lacks critical blockchain integration, KYC/AML infrastructure, and several Pre-ICO mandatory requirements.

Table of Contents

1. Executive Summary
2. Security Scores
3. Methodology
4. Scope & Architecture Overview
5. Backend API & Authentication Findings
6. Secrets Management Findings
7. Scraping Integration Risks
8. Blockchain Integration Readiness
9. CI/CD & Infrastructure Risks
10. GDPR/CCPA/KYC Readiness
11. Findings Summary Matrix
12. Missing Pre-ICO Requirements
13. Recommended Action Plan
14. Conclusion

1. Executive Summary

This report presents the results of a comprehensive Pre-ICO security, compliance, and architecture audit of the **Influencers CRM Backend** (Node.js/Express/TypeScript + Supabase). The audit was conducted to assess the readiness of the platform for an Initial Coin Offering (ICO) and identify security vulnerabilities, compliance gaps, and architectural risks that must be addressed before launch.

Key Strengths

- Strong JWT authentication with pluggable key providers (Env/AWS KMS/AWS Secrets Manager)
- Fail-closed token revocation with persistent blocklist and LRU cache fallback
- Comprehensive input validation and XSS/prototype-pollution sanitization
- GDPR privacy framework with consent management, DSAR, data export, erasure, and retention
- Structured audit logging with IP anonymization
- CI/CD with CodeQL, dependency review, and npm audit
- Multi-stage Docker build with non-root user
- HTTPS enforcement, Helmet security headers, CORS, and rate limiting

Critical Gaps

- **No blockchain integration** — no smart contracts, wallet authentication, or token infrastructure
- **No KYC/AML system** — mandatory for ICO compliance in most jurisdictions
- **No multi-factor authentication (MFA)** — required for financial/token platforms
- **Supabase service key used server-side** — bypasses Row Level Security policies
- **No database encryption-at-rest configuration documented**
- **No penetration test or third-party audit evidence**

2. Security Scores

7.5/10 API & Auth Security	**8.0/10** Secrets Management	**6.5/10** Scraping Integration
1.0/10 Blockchain Readiness	**7.0/10** CI/CD & Infrastructure	**6.5/10** GDPR/CCPA/KYC Readiness

Category	Score	Assessment
API & Authentication Security	7.5 / 10	Strong fundamentals; lacks MFA and RBAC granularity
Secrets Management	8.0 / 10	Excellent key-provider abstraction with KMS/SM support; rotation built-in
Scraping Integration Security	6.5 / 10	HTTPS enforced + Zod validation; lacks retry circuit-breaker and SSRF allow-list
Blockchain Integration	1.0 / 10	No blockchain code, smart contracts, or wallet integration exists
CI/CD & Infrastructure	7.0 / 10	Good pipeline; missing SAST, container scanning, and staging environments
GDPR/CCPA/KYC Compliance	6.5 / 10	Good GDPR framework; no KYC/AML, no DPO contact, no cookie consent
OVERALL WEIGHTED SCORE		**6.1 / 10 — PARTIALLY READY**

3. Methodology

This audit follows OWASP Top 10 (2021), CWE/SANS Top 25, ISO 27001 controls, and SEC/FINRA ICO guidance. Analysis was performed via:

- **Static Analysis:** Manual code review of all 37 source files, 6 SQL migrations, 3 CI workflows, and Docker configuration
- **Dependency Analysis:** Review of 14 production dependencies and 14 dev dependencies
- **Architecture Review:** Evaluation of middleware pipeline, service layer, and data flow
- **Compliance Mapping:** GDPR Articles 5-25, CCPA §§1798.100-1798.199, FinCEN/SEC ICO requirements

4. Scope & Architecture Overview

Technology Stack

Component	Technology	Version
Runtime	Node.js	≥20
Framework	Express	5.2.1
Language	TypeScript	6.0.2
Database	Supabase (PostgreSQL)	Client 2.101.1
Validation	Zod	4.3.6
Authentication	jsonwebtoken (HS256)	9.0.3
External API	ScrapeCreators API (Axios)	1.15.0
Logging	Pino	10.3.1
Container	Docker (node:20-alpine)	Multi-stage

Architecture Diagram (Middleware Pipeline)

```
Request → requireHttps → requestId → helmet → cors → json(1mb) → rateLimit(100/15min)
  → /health (public)
  → /api/auth/* (authenticate → handler)
  → /api/influencers/* (authenticate → sanitizeBody → auditLog → validate → handler)
  → /api/privacy/* (authenticate → sanitizeBody → auditLog → validate → handler)
  → errorHandler (centralized, no stack traces)
```

Route Map

Route Group	File	Endpoints	Auth
/health	src/app.ts:71	GET /health	None
/api/auth	src/routes/auth.ts	POST /logout	JWT
/api/influencers	src/routes/influencers.ts	POST /search, POST /bulk-search, GET /, GET /:id, PATCH /:id, DELETE /:id (admin), POST /:id/outreach	JWT + RBAC
/api/privacy	src/routes/privacy.ts	GET /consent, POST /consent, GET /requests, POST /requests, PATCH /requests/:id (admin), GET /export, DELETE /data, POST /purge (admin)	JWT + RBAC

5. Backend API & Authentication Findings

ID	Severity	Finding	Location	Description	Recommendation
`API-01`	HIGH	No Multi-Factor Authentication (MFA)	src/middleware/auth.ts:17-56	Authentication relies solely on JWT bearer tokens (HS256). For a platform handling financial transactions and token sales, single-factor authentication is insufficient. No TOTP, WebAuthn, or SMS verification layer exists.	Implement MFA via TOTP (e.g., speakeasy) or integrate Supabase MFA. Critical for ICO participants managing wallets/tokens.
`API-02`	HIGH	Supabase Service Key Bypasses RLS	src/services/supabase.ts:4,10	The application uses `SUPABASE_SERVICE_KEY` (service role key) which bypasses all Row Level Security policies. Any application-level bug could result in unrestricted database access across all tenants.	Implement a secondary Supabase client using the anon key + user JWT for user-scoped queries. Reserve service key for admin operations only. Add RLS policies to all tables.
`API-03`	MEDIUM	HS256 Symmetric JWT Signing	src/middleware/auth.ts:40-41	JWT verification uses HS256 (symmetric key). If the shared secret is compromised, attackers can forge tokens. RS256/ES256 (asymmetric) is preferred for production, especially for ICO platforms.	Migrate to RS256 or ES256 asymmetric algorithms. The keyProvider abstraction already supports this transition.
`API-04`	MEDIUM	No JWT Audience/Issuer Validation	src/middleware/auth.ts:40-42	`jwt.verify()` does not validate `iss` (issuer) or `aud` (audience) claims. A valid JWT from another Supabase project using the same secret could be accepted.	Add `issuer` and `audience` options to `jwt.verify()`.
`API-05`	MEDIUM	Rate Limiter Not Keyed by Authenticated User	src/app.ts:58-66	Global rate limiter uses IP-based limiting (default). In cloud/proxy environments, many users share IPs. Authenticated endpoints should also rate-limit per user ID to prevent abuse.	Add per-user rate limiting using `req.user.sub` as key generator on authenticated routes.
`API-06`	MEDIUM	No CSRF Protection for State-Changing Endpoints	src/app.ts:41-48	While CORS is configured, no CSRF token mechanism exists. If the API is consumed by a browser-based SPA with cookie-based auth fallback, CSRF attacks are possible.	Implement CSRF tokens (e.g., csurf or custom double-submit cookie pattern) if browser-based consumption is planned.
`API-07`	LOW	No Request Body Size Differentiation	src/app.ts:53	Global 1MB body limit applies to all routes. Bulk-search with 50 handles could approach this limit. Export endpoints may need different limits.	Apply per-route body size limits for sensitive endpoints.
`API-08`	LOW	Wildcard Error Catching Hides Specific Failures	src/middleware/auth.ts:53	The catch block in auth middleware catches all errors generically. JWT-specific errors (expired, malformed, signature mismatch) are not differentiated for logging.	Log specific JWT error types (TokenExpiredError, JsonWebTokenError) for monitoring/alerting.
`API-09`	LOW	Bulk Search Processes Sequentially	src/controllers/influencers.controller.ts:274	Bulk search iterates handles sequentially with `for...of`. With 50 handles × 30s timeout = potential 25-minute request. No	Add Promise.allSettled with concurrency limit (e.g., p-limit) and an overall request timeout.

				overall timeout or concurrency limit.	
`API-10`	**LOW**	DELETE Influencer Does Not Cascade Cleanup Verification	src/controllers/influencers.controller.ts:199-222	Delete relies on DB CASCADE constraint (outreach FK). No application-level verification that related data (audit logs referencing the influencer) is handled.	Document the cascade behavior and ensure audit log entries referencing deleted influencers are retained for compliance.

6. Secrets Management Findings

ID	Severity	Finding	Location	Description	Recommendation
`SEC-01`	HIGH	CI Workflow Hardcoded Fallback Secrets	.github/workflows/ci.yml:40-43	CI env vars use `|| 'test-jwt-secret...'` fallback syntax. While this is for testing, the pattern could accidentally leak into production workflows. The fallback JWT secret is predictable and <64 chars.	Use dedicated CI secrets without fallback defaults. Set minimum secret length requirements.
`SEC-02`	MEDIUM	No JWT Secret Minimum Length Enforcement	src/services/keyProvider.ts:58-63	`EnvKeyProvider` checks only for presence of the secret, not minimum length. HMAC-SHA256 requires at least 256 bits (32 bytes) for security, but weak secrets are accepted.	Add minimum length validation (≥32 characters) in `EnvKeyProvider.initialize()`.
`SEC-03`	MEDIUM	ScrapeCreators API Key in Module-Level Variable	src/services/scrapeCreators.ts:6-9	The API key is read at module load time and stored as a module-level constant. It cannot be rotated without restarting the server. Process memory dumps could expose it.	Refactor to use a lazy-loading pattern similar to keyProvider, supporting runtime rotation.
`SEC-04`	LOW	.env.example Contains Placeholder Secrets	.env.example:1-4	While using placeholders is standard practice, the file is committed to the repository. Developers may accidentally commit a real `.env` file.	Add a pre-commit hook (e.g., git-secrets, detect-secrets) to prevent accidental secret commits. ✅ .gitignore already excludes .env.

7. Scraping Integration Risks

ID	Severity	Finding	Location	Description	Recommendation
`SCR-01`	HIGH	No SSRF Domain Allow-List	src/services/scrapeCreators.ts:24-30	The HTTPS interceptor blocks non-HTTPS URLs but does not restrict the target domain. If a future code change introduces a configurable base URL, it could be exploited for SSRF. Currently, URLs are hardcoded to `api.scrapecreators.com`, but there is no explicit domain allow-list enforcement.	Add a URL allow-list filter (e.g., only `api.scrapecreators.com`) in the request interceptor.
`SCR-02`	MEDIUM	No Circuit Breaker / Retry Logic	src/services/scrapeCreators.ts:195	API calls to ScrapeCreators have a 30s timeout but no retry logic or circuit breaker. If the external API is down, each request will wait 30s before failing. Bulk search with 50 handles could hang for 25 minutes.	Implement a circuit breaker pattern (e.g., opossum) and exponential backoff retry with max attempts.
`SCR-03`	MEDIUM	Scraped Data Stored Without Consent Verification	src/controllers/influencers.controller.ts:38-48	Social media profiles are scraped and stored without verifying that the user has consent to process the influencer's data. Under GDPR Art. 6, a legal basis (legitimate interest or consent) must be documented per influencer.	Add a consent/legal-basis field to the influencer record. Document legitimate interest assessment for public profile scraping.
`SCR-04`	MEDIUM	No Rate Limiting on Outbound ScrapeCreators API	src/services/scrapeCreators.ts:12-17	No outbound rate limiting is applied to ScrapeCreators API calls. An attacker could trigger many searches (within the inbound rate limit) causing excessive API usage and potential billing impact.	Add an outbound rate limiter (e.g., bottleneck or p-throttle) to cap ScrapeCreators API calls/minute.
`SCR-05`	LOW	Zod Schema Uses .passthrough()	src/services/scrapeCreators.ts:63,70-71	The Zod schemas use `.passthrough()` which allows unknown fields to pass through validation. While this handles API response evolution, unexpected fields could contain malicious data that is stored in the database.	Use `.strip()` instead of `.passthrough()` to only keep known fields, or add sanitization to passed-through fields.
`SCR-06`	LOW	No Response Caching for Repeated Searches	src/services/scrapeCreators.ts:172-214	Identical search requests always hit the external API. No caching layer reduces redundant external calls, increasing latency and cost.	Add a short-lived cache (LRU or Redis) for recent scrape results, respecting data freshness via `last_scraped`.

8. Blockchain Integration Readiness

🚫 NOT READY — No Blockchain Integration Found

The repository contains **zero blockchain-related code, configuration, or infrastructure**. For a Pre-ICO assessment, this is the most critical gap.

ID	Severity	Missing Component	Description	Pre-ICO Requirement
`BLK-01`	HIGH	No Smart Contract Infrastructure	No Solidity/Rust contracts, no ABI definitions, no contract deployment scripts, no contract address management.	Token contract (ERC-20/BEP-20), vesting contract, ICO sale contract required.
`BLK-02`	HIGH	No Wallet Authentication	No Web3 wallet connection (MetaMask, WalletConnect), no SIWE (Sign-In with Ethereum), no wallet address linking to user accounts.	ICO participants must connect wallets to purchase tokens.
`BLK-03`	HIGH	No Token Economy / Tokenomics	No token supply definition, no vesting schedules, no token distribution logic, no whitelist management.	Tokenomics model, whitelist/KYC gating, contribution tracking.
`BLK-04`	HIGH	No Blockchain Transaction Tracking	No transaction hash storage, no event listener for on-chain events, no block confirmation tracking.	Transaction monitoring, confirmation tracking, event indexing.
`BLK-05`	HIGH	No Smart Contract Audit	No contracts exist to audit. Pre-ICO requires third-party smart contract security audit (CertiK, OpenZeppelin, Trail of Bits).	Independent smart contract audit report required before token sale.
`BLK-06`	MEDIUM	No Multi-Sig / Treasury Wallet	No multi-signature wallet configuration for ICO fund management. No Gnosis Safe or similar integration.	Multi-sig treasury for raised funds, timelocked withdrawals.

9. CI/CD & Infrastructure Risks

ID	Severity	Finding	Location	Description	Recommendation
`INF-01`	**HIGH**	No Container Image Scanning	Dockerfile, .github/workflows/	Docker image is built but never scanned for OS-level CVEs (Alpine packages, node binaries). No Trivy, Snyk Container, or Grype integration.	Add container image scanning (Trivy/Snyk) to CI pipeline before deployment.
`INF-02`	**HIGH**	No Deployment Pipeline / CD	.github/workflows/	CI pipeline builds and tests but has no deployment stage. No staging, pre-production, or production deployment workflow. No infrastructure-as-code.	Add deployment workflows with environment promotion (staging → production). Use IaC (Terraform/Pulumi).
`INF-03`	**MEDIUM**	No SAST Tool Beyond CodeQL	.github/workflows/codeql.yml	CodeQL provides good analysis but additional SAST tools (Semgrep, ESLint security plugin) would increase coverage. No secret scanning (git-secrets, truffleHog) in pipeline.	Add Semgrep or eslint-plugin-security to CI. Add secret scanning step.
`INF-04`	**MEDIUM**	No DAST / Runtime Security Testing	N/A	No dynamic application security testing (OWASP ZAP, Burp Suite automation) is performed against a running instance.	Add DAST scanning in CI against a test deployment.
`INF-05`	**MEDIUM**	Docker Image Uses Mutable Base Tag	Dockerfile:4,19	Base image `node:20-alpine` uses a mutable tag. Builds are not reproducible; a compromised upstream image could affect production.	Pin to a specific digest: `node:20-alpine@sha256:...`.
`INF-06`	**MEDIUM**	No Health Check in Dockerfile	Dockerfile:37	Docker image has no HEALTHCHECK instruction. Container orchestrators (ECS, K8s) won't know if the app is healthy without external probe configuration.	Add `HEALTHCHECK CMD curl -f http://localhost:3001/health || exit 1`.
`INF-07`	**LOW**	No Database Migration Runner	migrations/	SQL migrations exist but there is no automated migration runner. Migrations must be applied manually via Supabase dashboard or psql.	Add a migration runner (e.g., db-migrate, node-pg-migrate, or Supabase CLI) integrated with deployment.
`INF-08`	**LOW**	No Monitoring / APM Integration	N/A	No application performance monitoring (Datadog, New Relic, Sentry) integration. Error tracking relies on Pino logs only.	Integrate APM/error tracking (Sentry for errors, Datadog for metrics).

10. GDPR/CCPA/KYC Readiness

10.1 GDPR Compliance Assessment

GDPR Article	Requirement	Status	Details
Art. 5	Data processing principles	✅ Partial	Purpose limitation documented. Data minimization could be improved (scraper stores all available fields).
Art. 6	Lawfulness of processing	⚠️ Gap	No per-influencer legal basis documented. Consent framework exists for users but not for scraped data subjects.
Art. 7	Conditions for consent	✅ Implemented	Granular consent management via /api/privacy/consent (src/routes/privacy.ts:39-40).
Art. 12-14	Transparency	✅ Implemented	Privacy Policy (docs/PRIVACY_POLICY.md) and ToS (docs/TERMS_OF_SERVICE.md) exist.
Art. 15	Right of access	✅ Implemented	GET /api/privacy/export (src/routes/privacy.ts:68). DSAR request type 'access'.
Art. 17	Right to erasure	✅ Implemented	DELETE /api/privacy/data (src/routes/privacy.ts:75). Audit logs anonymized, not deleted.
Art. 20	Data portability	✅ Implemented	JSON export via GET /api/privacy/export (src/controllers/privacy.controller.ts:126-143).
Art. 25	Data protection by design	✅ Partial	IP anonymization, sanitization, encryption in transit. Missing encryption at rest documentation.
Art. 28	Data processor agreements	✅ Implemented	DPA template at docs/DATA_PROCESSING_AGREEMENT.md.
Art. 30	Records of processing	✅ Implemented	Audit log (src/services/auditLog.ts) records all state-changing operations.
Art. 33	Breach notification	⚠️ Gap	No breach notification mechanism or incident response procedure documented.
Art. 35	DPIA	❌ Missing	No Data Protection Impact Assessment for social media scraping.
Art. 37	Data Protection Officer	❌ Missing	No DPO designation or contact information. Required if processing at scale.

10.2 KYC/AML Findings

ID	Severity	Finding	Description	Requirement
`KYC-01`	**HIGH**	No KYC System	No Know Your Customer verification exists. No identity document collection, no verification provider (Jumio, Onfido, Sumsub), no identity status tracking.	Mandatory for ICO in most jurisdictions (SEC, FCA, MAS, BaFin). Must verify investor identity before token purchase.
`KYC-02`	**HIGH**	No AML Screening	No Anti-Money Laundering checks. No sanctions list screening (OFAC, EU, UN), no PEP (Politically Exposed Persons) checks, no transaction monitoring.	Required under BSA/FinCEN (US), AMLD5/6 (EU), and most financial regulations.
`KYC-03`	**HIGH**	No Investor Accreditation Verification	No mechanism to verify accredited investor status (required for SEC Reg D offerings in the US).	Required for US-based token sales under SEC regulations.
`KYC-04`	**MEDIUM**	No Geographic Restriction Enforcement	No IP-based or residency-based geographic restrictions. ICOs typically must block sanctioned countries.	Implement geo-blocking for sanctioned jurisdictions (OFAC list).

10.3 Additional Compliance Findings

ID	Severity	Finding	Location	Description

`CMP-01`	**MEDIUM**	No DSAR Response Deadline Tracking	src/services/privacy.ts:78-100	DSAR requests are created with 'pending' status but no deadline enforcement (GDPR requires response within 30 days). No automated alerts when deadlines approach.
`CMP-02`	**MEDIUM**	Data Export Incomplete	src/services/privacy.ts:165-199	`exportUserData()` exports audit_logs, consents, and dsar_requests, but does NOT export influencer data that the user created/manages. Not all user data is portable.
`CMP-03`	**MEDIUM**	Erasure Does Not Delete Influencer Data	src/services/privacy.ts:209-262	`eraseUserData()` deletes consent records, anonymizes audit logs, and marks DSAR as completed — but does NOT delete influencer records created by the user, outreach records, or revoked tokens.
`CMP-04`	**LOW**	Privacy Policy is Template-Only	docs/PRIVACY_POLICY.md:158	Privacy policy and DPA are marked as templates ("should be customized"). For Pre-ICO, finalized, legally reviewed documents are required.
`CMP-05`	**LOW**	No Cookie/Tracking Consent Banner Integration	N/A	If a frontend is deployed, cookie consent (ePrivacy Directive) will be needed. Backend has no cookie consent tracking endpoint.

11. Findings Summary Matrix

Category	High	Medium	Low	Total
API & Authentication	2	4	4	10
Secrets Management	1	2	1	4
Scraping Integration	1	3	2	6
Blockchain Readiness	5	1	0	6
CI/CD & Infrastructure	2	4	2	8
GDPR/CCPA/KYC	3	4	2	9
TOTAL	**14**	**18**	**11**	**43**

Severity Distribution

HIGH — 14 findings (32.6%)	Must be resolved before ICO launch
MEDIUM — 18 findings (41.9%)	Should be resolved; acceptable risk with mitigation plan
LOW — 11 findings (25.6%)	Recommended improvements; not blocking

12. Missing Pre-ICO Requirements

The following components are **mandatory** for most ICO launches and are entirely absent from the codebase:

#	Requirement	Status	Criticality
1	ERC-20/BEP-20 Token Smart Contract	❌ Missing	**BLOCKER**
2	ICO/Token Sale Smart Contract	❌ Missing	**BLOCKER**
3	Smart Contract Security Audit (3rd party)	❌ Missing	**BLOCKER**
4	KYC/AML Verification System	❌ Missing	**BLOCKER**
5	Wallet Authentication (SIWE/Web3)	❌ Missing	**BLOCKER**
6	Multi-Factor Authentication	❌ Missing	**BLOCKER**
7	Investor Whitelist Management	❌ Missing	**BLOCKER**
8	Token Vesting/Lockup Contracts	❌ Missing	**HIGH**
9	Multi-Sig Treasury Wallet	❌ Missing	**HIGH**
10	Penetration Test Report	❌ Missing	**HIGH**
11	Data Protection Impact Assessment (DPIA)	❌ Missing	**MEDIUM**
12	Incident Response Plan	❌ Missing	**MEDIUM**
13	Legal Opinion / Regulatory Compliance Letter	❌ Missing	**BLOCKER**
14	Whitepaper / Technical Documentation	❌ Missing	**MEDIUM**
15	Deployment & Runbook Documentation	❌ Missing	**MEDIUM**

13. Recommended Action Plan

Phase 1: Critical Blockers (Weeks 1–4)

1.1 Implement KYC/AML System
Integrate a KYC provider (Jumio, Onfido, or Sumsub). Create user verification status tracking tables. Add sanctions screening. Block unverified users from token-related operations.

1.2 Build Blockchain Infrastructure
Develop ERC-20 token contract (use OpenZeppelin templates). Build ICO sale contract with whitelist, caps, and vesting. Deploy to testnet. Engage a third-party auditor (CertiK, Trail of Bits).

1.3 Add Web3 Wallet Authentication
Integrate SIWE (Sign-In with Ethereum) or WalletConnect. Link wallet addresses to user accounts. Add wallet-based authorization for token operations.

1.4 Implement Multi-Factor Authentication
Add TOTP-based MFA (speakeasy + qrcode). Make MFA mandatory for admin roles and token purchase flows. Consider WebAuthn for hardware key support.

1.5 Obtain Legal Opinion
Engage securities law counsel for regulatory compliance review. Determine token classification (utility vs. security). Prepare regulatory filings as required.

Phase 2: High Priority (Weeks 4–8)

2.1 Fix Supabase RLS Architecture
Implement Row Level Security policies on all tables. Create a user-scoped Supabase client. Reserve service key for admin operations only.
File: src/services/supabase.ts

2.2 Enhance CI/CD Pipeline
Add container image scanning (Trivy). Add SAST (Semgrep). Add secret scanning. Create deployment workflows with staging environment. Pin Docker base image digests.
Files: Dockerfile, .github/workflows/

2.3 Commission Penetration Test
Engage an external pen-testing firm. Test the API, infrastructure, and smart contracts. Address findings before launch.

2.4 Complete GDPR Compliance
Write DPIA for social media scraping. Appoint/document DPO. Finalize privacy policy and DPA (remove template disclaimers). Add DSAR deadline tracking. Fix data export/erasure to include influencer data.
Files: src/services/privacy.ts, docs/

Phase 3: Medium Priority (Weeks 8–12)

3.1 Strengthen Authentication
Migrate from HS256 to RS256/ES256. Add JWT audience/issuer validation. Add per-user rate limiting.
Files: src/middleware/auth.ts, src/app.ts

3.2 Harden Scraping Integration
Add SSRF domain allow-list. Implement circuit breaker. Add outbound rate limiting. Replace Zod .passthrough() with .strip().
File: src/services/scrapeCreators.ts

3.3 Add Monitoring & Observability
Integrate Sentry for error tracking. Add APM metrics (Datadog/New Relic). Create dashboards for security events.

3.4 Create Operational Documentation

Write deployment runbook. Document incident response procedures. Create whitepaper/technical docs.

14. Conclusion

⚠️ FINAL VERDICT: PARTIALLY READY

Overall Score: **6.1 / 10**

The **Influencers CRM Backend** demonstrates **solid backend engineering practices** with well-structured middleware, comprehensive input validation, fail-closed security patterns, and a thoughtful GDPR compliance framework. These are strong foundations.

However, the application is **fundamentally an influencer CRM**, not a blockchain/ICO platform. The following **critical blockers** prevent ICO readiness:

1. **Zero blockchain integration** — no smart contracts, no wallet auth, no token infrastructure
2. **No KYC/AML system** — legally required in virtually all jurisdictions for token sales
3. **No MFA** — insufficient for a financial/token platform
4. **No smart contract audit** — required before any token sale
5. **No legal/regulatory compliance opinion**

Key Concerns

- The Supabase service key architecture bypasses database-level access controls
- Scraped influencer data is stored without documented legal basis per GDPR Art. 6
- No incident response or breach notification procedures exist
- CI/CD pipeline lacks container scanning and deployment stages
- Data export and erasure functions are incomplete (missing influencer data)

Estimated Effort to ICO Readiness

Phase	Duration	Team Size
Phase 1: Critical Blockers	4–6 weeks	3–4 engineers + legal counsel
Phase 2: High Priority	4 weeks	2–3 engineers
Phase 3: Medium Priority	4 weeks	2 engineers
Smart Contract Audit	2–4 weeks	External auditor
Penetration Testing	1–2 weeks	External pen-testers
Total Estimated	**12–16 weeks from today**	

Disclaimer: This audit report is based on static analysis of the source code repository as of April 10, 2026. It does not include runtime testing, penetration testing, or smart contract auditing. The findings and recommendations are advisory in nature. Organizations should engage qualified security professionals, legal counsel, and regulatory advisors for a complete Pre-ICO assessment. This report should not be construed as legal advice.

— End of Report —